[LOGO AREA]

AMMAR ALZAIEM

CYBERSECURITY | VAPT

SECURITY ASSESSMENT REPORT

TryHackMe – Pyramid of Pain

REPORT ID	AZ-EH-2026-007
VERSION	1.0
ASSESSMENT DATE	18/10/2026
REPORT DATE	22/10/2026
PREPARED BY	Ammar Alzaiem
CLASSIFICATION	Public

Overview

This room introduces the Pyramid of Pain, a model used to understand how difficult it is for an attacker to change different indicators associated with their activity.

The main idea is that not all indicators are equally useful for defenders. Blocking a single malicious IP address might stop one connection, but an attacker could switch to another address. Detecting the techniques they use can be much harder for them to work around.

The room also introduces resources such as VirusTotal, malware analysis reports, and network traffic analysis tools that can help identify suspicious activity.

1. The Pyramid of Pain

The Pyramid of Pain ranks indicators based on how much difficulty they cause an attacker when defenders detect and block them.

The six levels, from the bottom to the top, are:

Level	Indicator	Difficulty for the attacker
1	Hash values	Trivial
2	IP addresses	Easy
3	Domain names	Simple
4	Network and host artifacts	Annoying
5	Tools	Challenging
6	Tactics, Techniques and Procedures (TTPs)	Tough

The higher you move up the pyramid, the more work an attacker may need to do to avoid detection.

For example, changing a file slightly can produce a different hash. However, changing an entire attack method to avoid behavioral detection may require considerably more effort.

This doesn't mean lower-level indicators are useless. They can still be valuable for quickly identifying known threats. The point is to combine them with detections that are harder to evade.

2. Hash Values

A hash is a fixed-length value generated from data using a hashing algorithm. Security analysts use hashes to identify and track suspicious files.

Common algorithms include MD5, SHA-1, and SHA-256. MD5 and SHA-1 have known security weaknesses and should not be treated as collision-resistant cryptographic hashes.

Hashes are useful when investigating malware because a known malicious file can be searched for using its hash instead of relying on its filename.

However, hash-based detection has a limitation: even a small change to a file can produce a different cryptographic hash. An attacker may therefore evade a detection rule that relies only on a particular file hash.

3. IP Addresses and Domain Names

IP addresses and domain names can help analysts identify infrastructure used by malicious activity.

IP addresses

A defender may block a known malicious IP address using a firewall or another security control. This can prevent connections to that address, but attackers can change infrastructure or use alternative addresses.

The room also introduces Fast Flux, a technique that uses rapidly changing DNS records and multiple IP addresses to make malicious infrastructure harder to track.

Domain names

Domain names are often easier for people to recognise than IP addresses, and they can provide useful indicators during an investigation.

Attackers may use lookalike domains, shortened URLs, or Unicode characters to make a malicious address appear legitimate.

A Punycode representation can encode certain internationalised domain names into an ASCII-compatible format. This is relevant when investigating lookalike domains that use visually similar characters.

Analysts can investigate domain-related activity using DNS records, proxy logs, web server logs, and malware sandbox reports.

4. Host and Network Artifacts

Host and network artifacts are traces that suspicious activity leaves behind. These can provide more context than a hash or IP address alone.

Host artifacts

Host artifacts are observable on an individual system. Examples include:

- Files created or modified by a suspicious process.

- Unusual registry changes.
- Unexpected process execution.
- Suspicious parent-child process relationships.

For example, if an Office application launches an unusual executable, that behavior may deserve investigation, especially if it occurs alongside other suspicious events.

Network artifacts

Network artifacts appear in network communications. Examples include:

- Unusual HTTP User-Agent strings.
- Suspicious URL or URI patterns.
- Unexpected HTTP POST requests.
- Communication patterns associated with command-and-control infrastructure.

A packet capture can help reveal these patterns. Tools such as Wireshark and TShark allow analysts to inspect network traffic and extract relevant fields.

For example, TShark can extract HTTP hostnames and User-Agent values from a packet capture:

```
tshark -Y 'http.request' -T fields \
  -e http.host -e http.user_agent \
  -r analysis_file.pcap
```

This command filters for HTTP requests and displays their host and User-Agent fields. It only reveals information present in the capture and available for the selected protocol fields.

5. Tools and Detection Rules

Attackers use tools to carry out activities such as credential theft, malware execution, and command-and-control communication.

Detecting a particular tool can be useful, but attackers may modify it, replace it, or switch to another tool that performs the same task.

Defenders can use several resources to investigate and detect these activities:

- YARA: Identifies files based on defined patterns.
- Antivirus signatures: Detect known malicious files or characteristics.
- Detection rules: Identify suspicious events or activity patterns.

- Fuzzy hashing: Helps compare files for similarity, even when they aren't identical.

The room introduces SSDeep as an example of fuzzy hashing. Unlike a conventional cryptographic hash comparison, fuzzy hashing can help identify similarities between files that have been modified.

These techniques have limitations. A detection rule may produce false positives or miss modified samples, so results still need to be investigated.

6. Tactics, Techniques and Procedures (TTPs)

TTPs describe how an attacker operates.

- Tactics: The attacker's objective, such as gaining initial access or maintaining persistence.
- Techniques: The methods used to achieve that objective.
- Procedures**:** The specific way an attacker implements those methods.

MITRE ATT&CK is a knowledge base that organises observed adversary tactics and techniques.

For example, instead of detecting only one malicious executable, a defender might investigate suspicious script execution, unusual persistence mechanisms, and unexpected outbound connections.

These behaviors can remain useful indicators even when an attacker changes individual files or infrastructure.

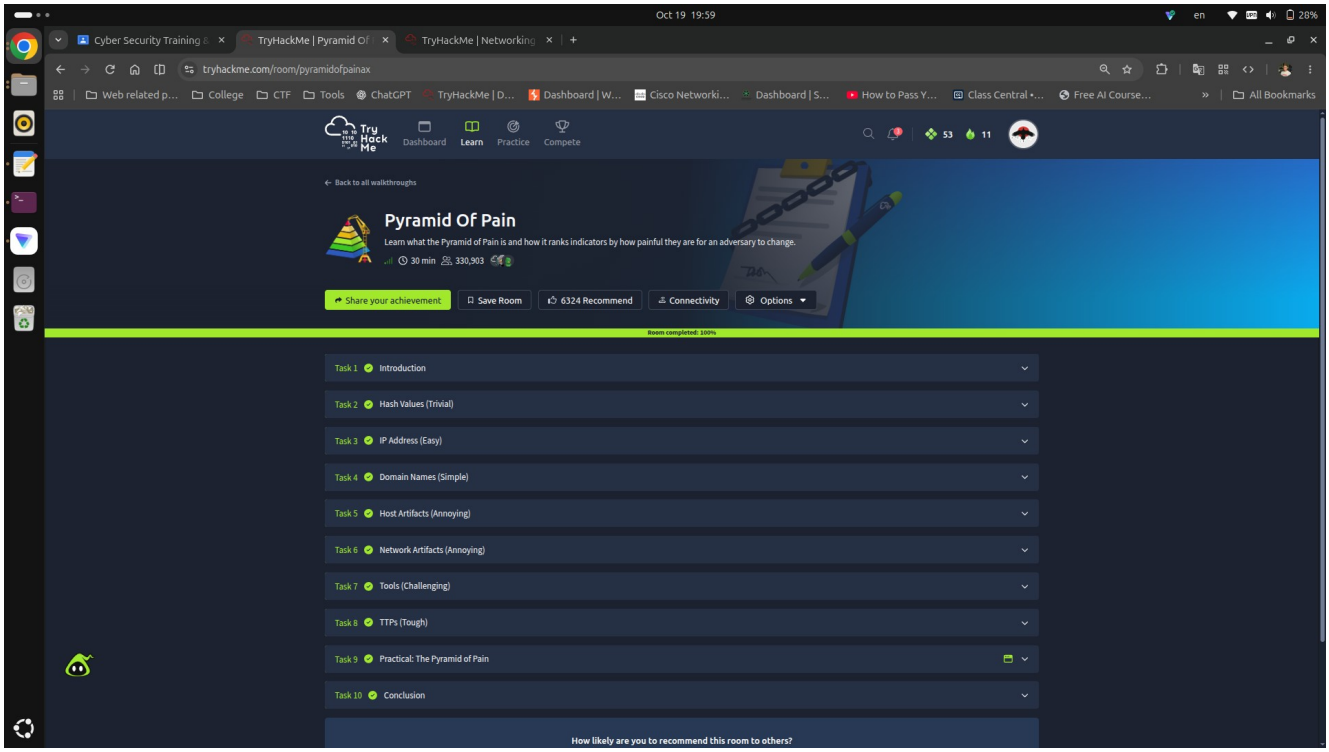
This is why TTPs sit at the top of the Pyramid of Pain: changing an entire approach can be much more difficult than changing one technical indicator.

Conclusion

This room helped me understand why threat detection shouldn't depend on a single indicator. Hashes, IP addresses, and domains are useful starting points, but they can change quickly.

Looking at process behavior, network traffic, and the techniques used during an attack can provide a more complete picture. The Pyramid of Pain gives defenders a way to think about which detections may create more work for an attacker.

These concepts are useful for understanding SOC analysis, threat hunting, and incident response, even though my main learning focus is penetration testing.


Oct 19 19:59
Cyber Security Training &
TryHackMe | Pyramid Of
TryHackMe | Networking
tryhackme.com/room/pyramidofpainax
Dashboard
Learn
Practice
Compete
Back to all walkthroughs
Pyramid Of Pain
Learn what the Pyramid of Pain is and how it ranks indicators by how painful they are for an adversary to change.
30 min
330,903
Share your achievement
Save Room
6324 Recommend
Connectivity
Options
Room completed: 100%
Task 1 Introduction
Task 2 Hash Values (Trivial)
Task 3 IP Address (Easy)
Task 4 Domain Names (Simple)
Task 5 Host Artifacts (Annoying)
Task 6 Network Artifacts (Annoying)
Task 7 Tools (Challenging)
Task 8 TTPs (Tough)
Task 9 Practical: The Pyramid of Pain
Task 10 Conclusion
How likely are you to recommend this room to others?